COMMERZBANK

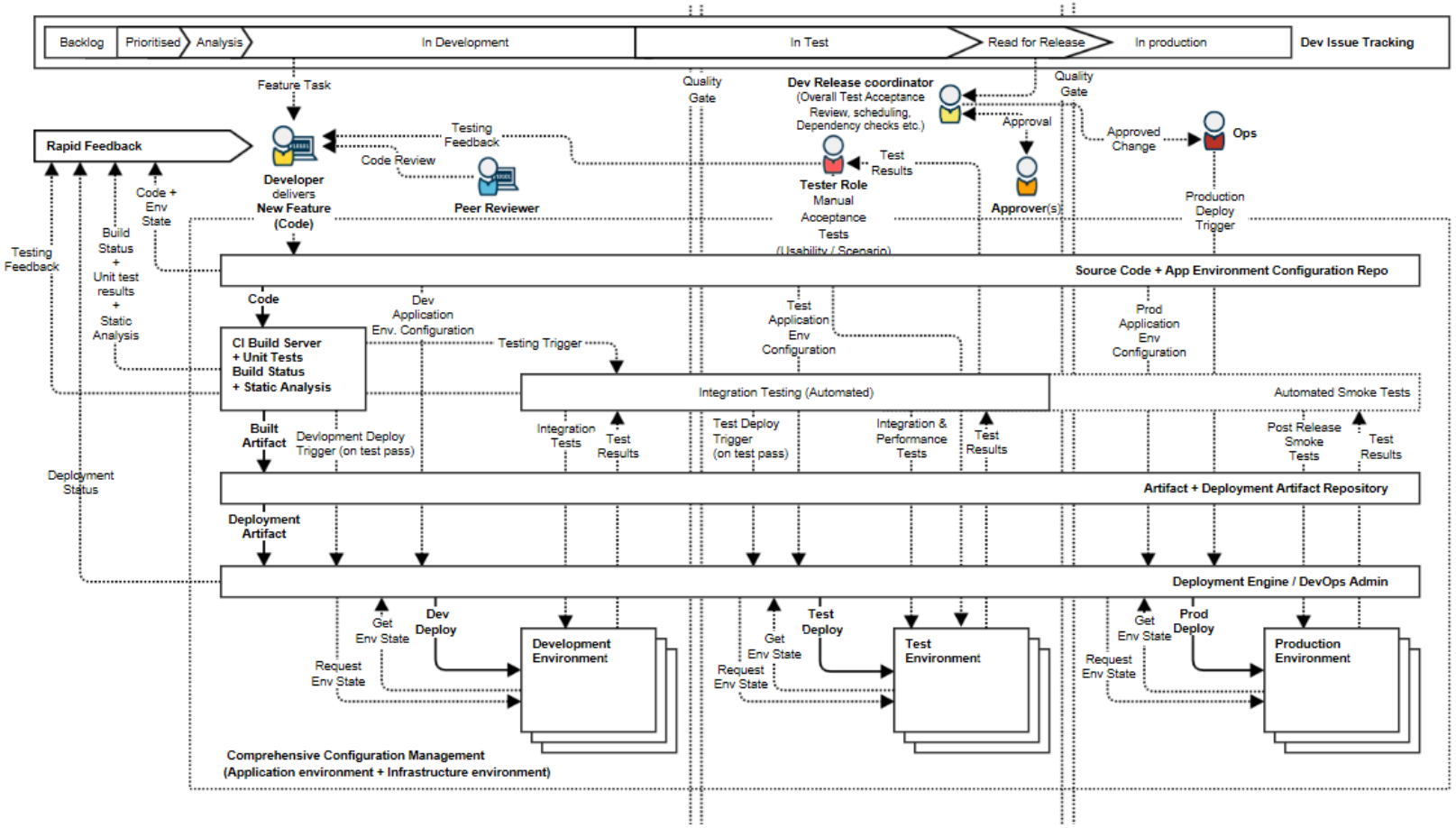
Securing the SDLC

Challenges of implementation

Sergey Egorov | GS-OS IS London | 01.03.2017

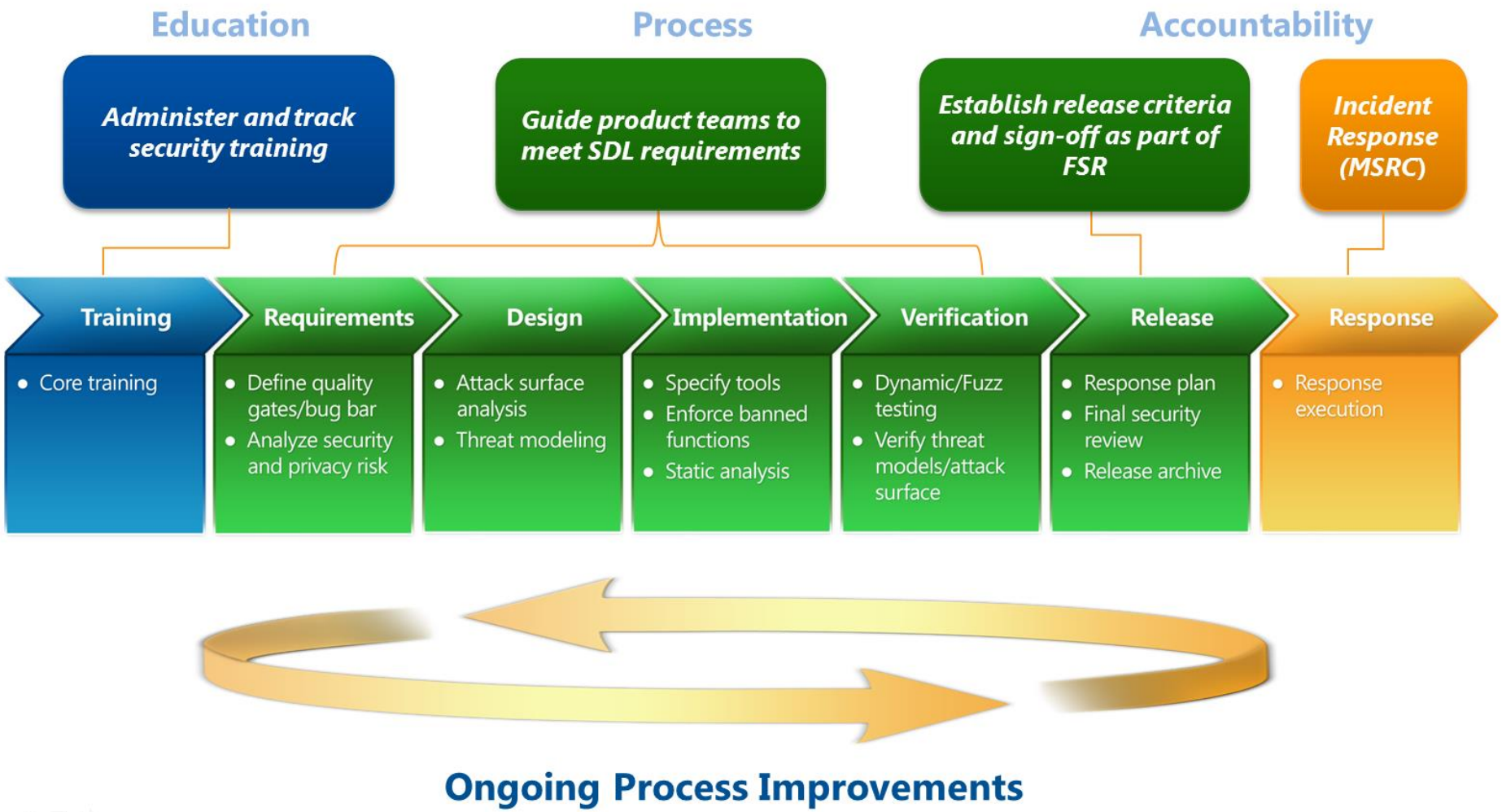
COMMERZBANK

System Development Lifecycle (SDLC)


Backlog
Prioritised
Analysis
In Development
In Test
Read for Release
In production
Dev Issue Tracking
Feature Task
Quality Gate
Dev Release coordinator
(Overall Test Acceptance Review, scheduling, Dependency checks etc.)
Quality Gate
Approval
Approved Change
Ops
Rapid Feedback
Testing Feedback
Code Review
Developer delivers New Feature (Code)
Peer Reviewer
Test Results
Tester Role
Manual Acceptance Tests
(Usability / Scenario)
Approver(s)
Production Deploy Trigger
Code + Env State
Build Status + Unit test results + Static Analysis
Testing Feedback
Source Code + App Environment Configuration Repo
Code
Dev Application Env. Configuration
Testing Trigger
Test Application Env Configuration
Prod Application Env Configuration
CI Build Server + Unit Tests Build Status + Static Analysis
Integration Testing (Automated)
Automated Smoke Tests
Built Artifact
Devlopment Deploy Trigger (on test pass)
Integration Tests
Test Results
Test Deploy Trigger (on test pass)
Integration & Performance Tests
Test Results
Post Release Smoke Tests
Test Results
Deployment Status
Artifact + Deployment Artifact Repository
Deployment Artifact
Deployment Engine / DevOps Admin
Get Env State
Dev Deploy
Request Env State
Development Environment
Get Env State
Test Deploy
Request Env State
Test Environment
Get Env State
Prod Deploy
Request Env State
Production Environment
Comprehensive Configuration Management
(Application environment + Infrastructure environment)

Microsoft SDL

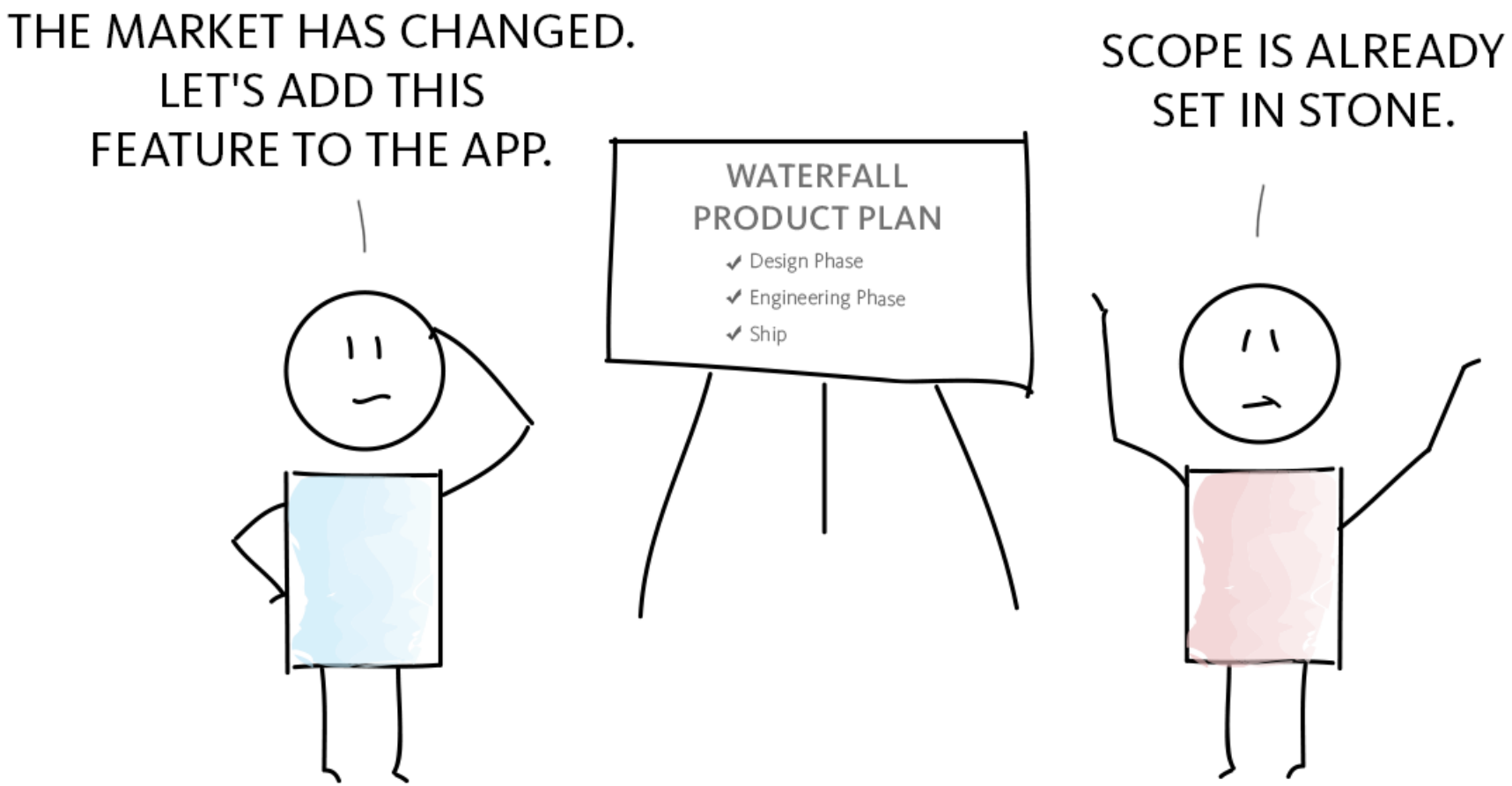
COMMERZBANK



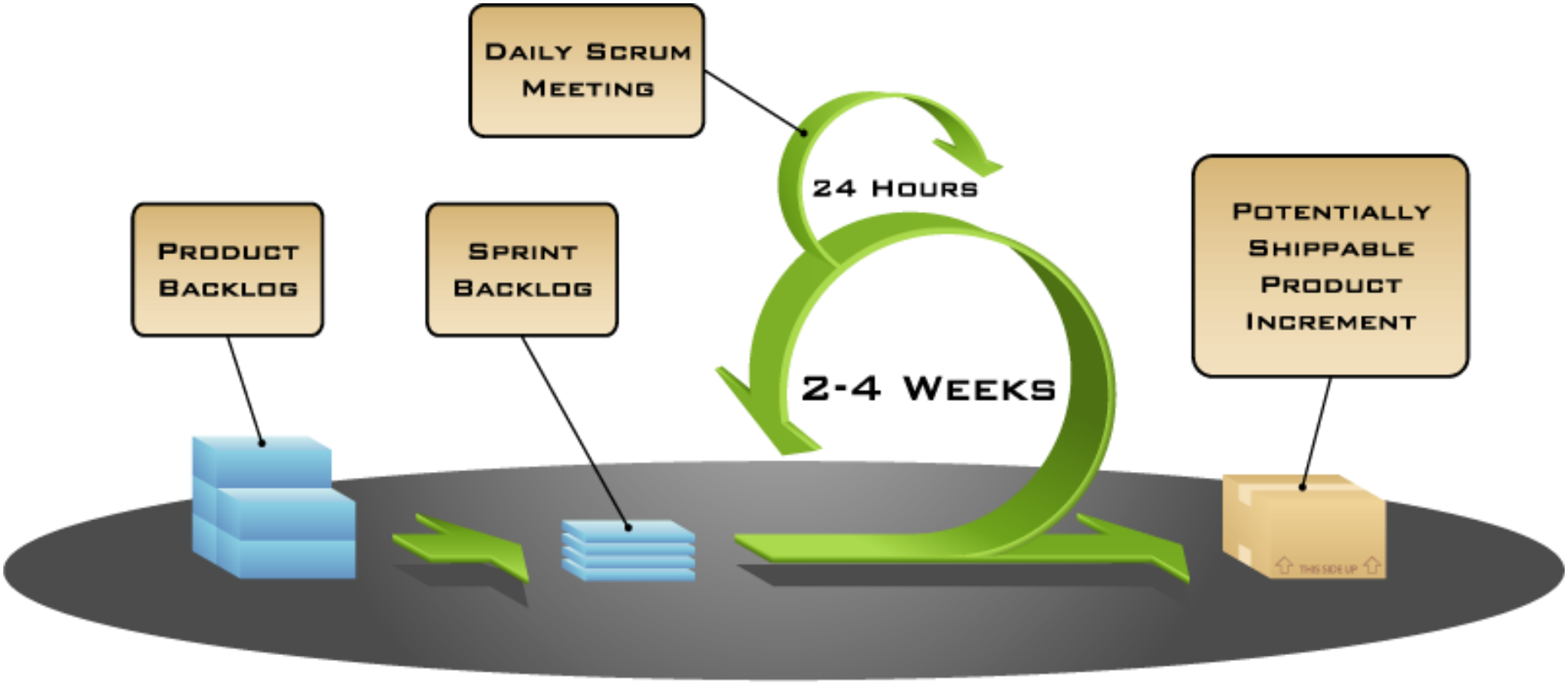
microsoft.com

SDL security controls:

- Requirements and Design
- Documentation and Approvals
- Secure Development and Testing
- Operational Security and Change Management


THE MARKET HAS CHANGED. LET'S ADD THIS FEATURE TO THE APP.
WATERFALL PRODUCT PLAN
Design Phase
Engineering Phase
Ship
SCOPE IS ALREADY SET IN STONE.

Agile & Scrum methods



wikimedia.org

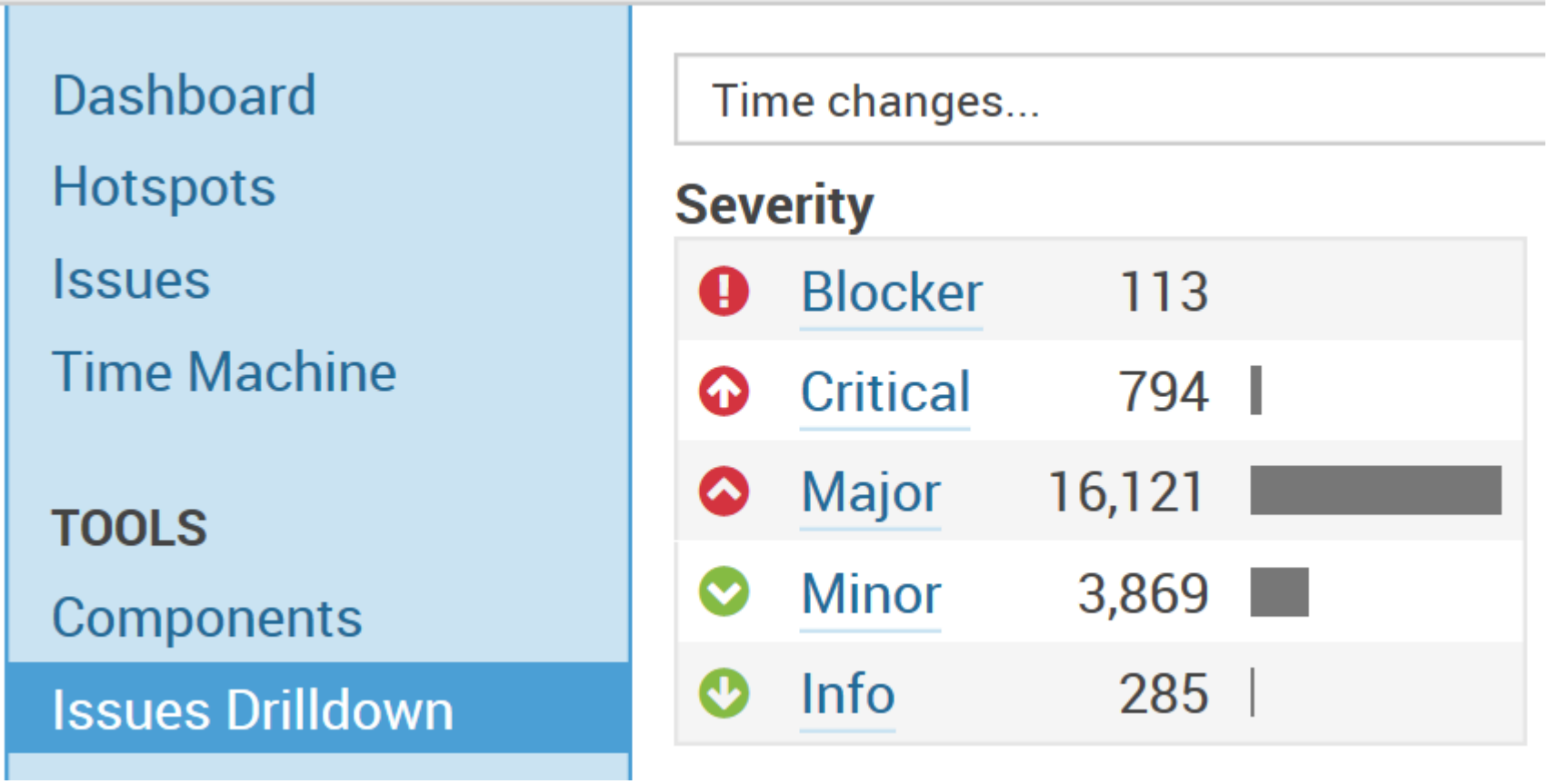
Cornerstones of development:

- Improper planning, cost and time driven
- Lack of coordination, ad-hoc developments
- Steep learning curve
- Middleware configured by developers
- Uncontrolled usage of external dependencies

As a result:

- Confusion with development frameworks
- Shadow IT zones
- Security practices remain aside
- Irrelevant documentation
- Bad designs leading to critical vulnerabilities

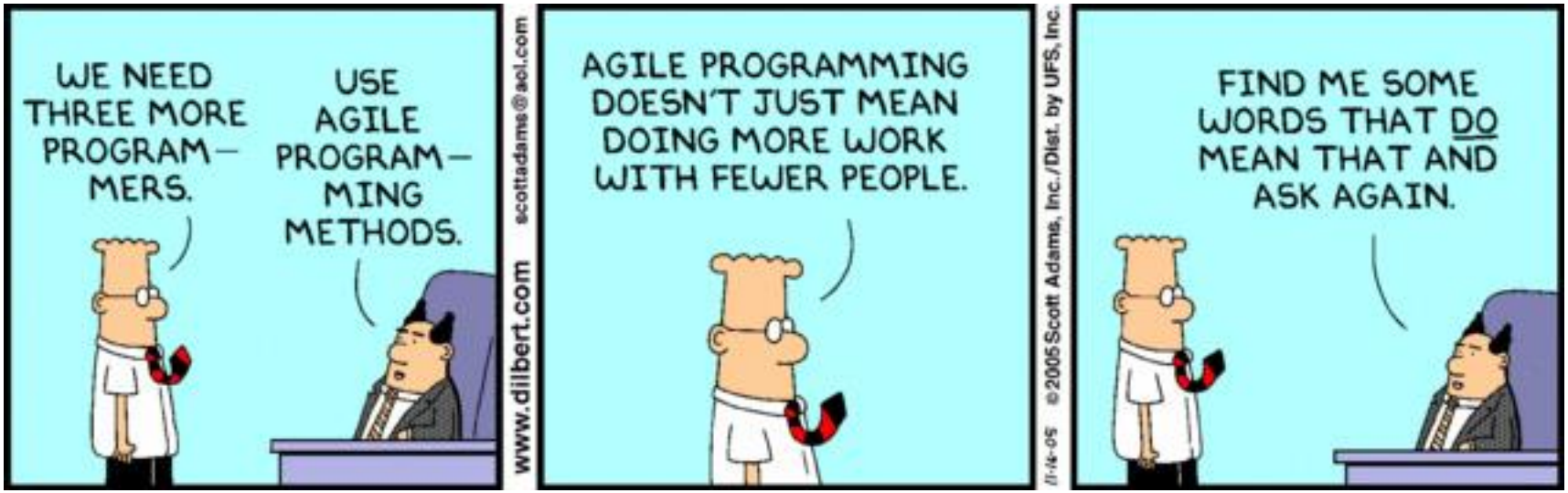
Static code analysis (SAST) results:



Centralization and automation:

- Centrally coordinated
- Integrated security mechanisms
- Structured documentation flexible for updates
- Collaboration, trainings, contextual learning

Questions?


WE NEED THREE MORE PROGRAM-MERS.
USE AGILE PROGRAM-MING METHODS.
www.dilbert.com
scottadams@aol.com
AGILE PROGRAMMING DOESN'T JUST MEAN DOING MORE WORK WITH FEWER PEOPLE.
11-14-05
©2005 Scott Adams, Inc./Dist. by UFS, Inc.
FIND ME SOME WORDS THAT DO MEAN THAT AND ASK AGAIN.